

TRAINING @ FORREST ONE

Session 5 of 12

Network Fundamentals + CompTIA Security+ SY0-701

Threats, Attack Types & Threat Actors

Who attacks, why they attack, and the paths they take: know the adversary before you defend.

LESSON 2

THREAT ACTORS

ATTACK VECTORS



WELCOME · WHERE WE ARE

Know the adversary

- **Session 4** set the CIA triad, controls and frameworks
- **Today** the adversary, in six chapters: actors, surface, vulnerabilities, malware, network attacks, mitigation
- **The relationship** a vulnerability plus a threat equals risk
- **The thread** every technique is paired with the control that answers it
- **The rule** you cannot defend against a threat you cannot name



SESSION OBJECTIVES

By the end of this session you will be able to

- **Define the terms** vulnerability, threat and risk, and how they combine
- **Compare threat actors** by resources, sophistication, motivation and intent
- **Classify actor types** nation-state, organised crime, hacktivist, unskilled, insider and shadow IT
- **Map the attack surface** the vectors that reach it, human vectors first
- **Explain vulnerabilities** software, application, operating system, hardware, mobile, cloud and virtualisation
- **Describe the attacks** malware and evasion, botnets, credential attacks, injection, denial of service, Layer 2, DNS, on-path
- **Apply the mitigations** segmentation, access control, hardening, patching and isolation



THREAT ACTORS

Vulnerability, threat and risk

- **Vulnerability** a weakness in a system, process or design
- **Threat** a person, tool or method that could exploit it
- **Risk** the likelihood and impact of that exploitation
- **The formula** a threat that exploits a vulnerability creates risk
- **The lesson** a weakness alone is not risk; add an adversary and it is

Every actor in this session supplies the capability, the motivation and the intent behind a risk.



THREAT ACTORS

Attributes of threat actors

Attribute	What it tells you
Resources	Money, technology and people the actor can commit
Sophistication	Skill, from ready-made tools to custom exploits
Motivation	The reason to act: money, ideology, grievance, curiosity
Intent	The specific outcome sought, such as theft or disruption

Motivation sets the reason and intent sets the outcome; together they predict the target.



THREAT ACTORS

Motivations and intent

- **Financial** ransomware, extortion, fraud, blackmail and card theft
- **Political or ideological** hacktivism, disinformation, protest and war
- **Strategic** espionage and data exfiltration
- **Personal** revenge, grievance, curiosity and disruption for its own sake
- **Ethical** authorised testing, research and responsible disclosure
- **The predictor** motivation chooses the target; intent chooses the outcome



THREAT ACTORS

Nation-state actors and advanced persistent threats

- **State sponsored** deep funding, advanced technology and highly skilled staff
- **Strategic goals** espionage, intellectual property theft and disruption
- **The APT** a prolonged, targeted campaign that stays undetected
- **Early stages** reconnaissance, intrusion, foothold, privilege escalation
- **Late stages** internal reconnaissance, exfiltration, persistence
- **Named cases** Stuxnet, Operation Aurora and NotPetya
- **Deniability** obfuscation and false-flag operations that defeat attribution

The APT is the most tested actor type on the exam: persistence, not one strike.



THREAT ACTORS

Organised crime and the underground economy

- **Structured like a business** hierarchies, specialist roles and profit as the only goal
- **Ransomware** encrypt the data, then demand cryptocurrency for the key
- **Banking trojans** capture financial details and redirect transactions
- **Card theft** skimming, phishing and weak e-commerce platforms
- **Business email compromise** impersonate an executive to authorise a payment
- **Crime as a service** rent botnets, ransomware and denial of service
- **Underground markets** stolen data and hacking tools, paid in cryptocurrency



THREAT ACTORS

Hacktivists, unskilled attackers and insiders

Actor	Profile	Typical method
Hacktivist	Ideological or political cause	Defacement, data leak, denial of service
Unskilled attacker	Script kiddie, no coding skill	Ready-made tools on easy targets
Malicious insider	Employee, contractor or partner	Theft or sabotage with valid access
Negligent insider	Authorised user who makes a mistake	Falls for phishing, mishandles data
Shadow IT	Unauthorised apps, devices, cloud services	Data placed outside approved controls

Insiders are hardest to detect because their access is legitimate.



THREAT ACTORS

Competitors and false flags

- **Competitors** espionage for intellectual property and trade secrets
- **Disinformation** damaging reputation as well as stealing an advantage
- **False flag** techniques that mislead attribution towards another actor
- **Attribution** hard by design, which is why behaviour and intent are analysed
- **Exam note** competitor motives and false flags are tested directly



DISCUSSION

Which threat actor type worries your organisation most, and why?

Walk each type: insider (authorised access), organised crime (ransomware), nation-state (espionage), hacktivist (disruption), unskilled attacker (whatever is unpatched). The answer depends on what the organisation holds.

Attribution drives defence: know who is most likely to value what you have.



QUIZ

Activity: match the actor

- A group defaces a government website to protest a policy, which type?
- An employee steals customer data to sell, which type?
- A state-sponsored team quietly exfiltrates defence research over a year, which type?
- An employee clicks a phishing link and causes a breach, which type?
- Debrief: which motivation and which attack surface does each answer reveal?

Type plus motivation together: hacktivist/political, insider/financial, APT/strategic, negligent insider/accidental.



ATTACK SURFACE

The attack surface

- **Definition** every point where an unauthorised user could enter or extract data
- **Scope** hardware, software, networks, processes and people
- **Cloud** data placed within reach of the internet
- **Mobile** sensitive data on hardware you do not fully control
- **Internet of Things** devices that ship with weak security
- **Remote work** home networks pulled inside your perimeter
- **The rule** a larger surface means more opportunities for breach

Reduce the surface, and you reduce the chances of a breach.



ATTACK SURFACE

Common threat vectors

Vector	How it reaches you
Phishing email	A deceptive message that persuades a user to act
Malware	Attachment, compromised website or infected media
Software vulnerability	A known flaw left unpatched
Social engineering	Manipulating a person into granting access
Wireless and cloud	Open wireless, rogue access points, exposed services

The surface is every door into your environment; a vector is how the attacker walks through one.



HUMAN VECTORS

The phishing family

Type	Who it targets
Phishing	Bulk deceptive email to a wide audience
Spear phishing	A named individual, using researched detail
Whaling	Executives and key decision makers
Smishing	The same deception sent by text message
Vishing	Voice phishing conducted over the telephone

Name the right member of the family in a scenario: the target defines the type.



HUMAN VECTORS

Social engineering techniques

- **Pretexting** a fabricated scenario, posing as a colleague, supplier or support
- **Baiting** a tempting lure, such as a dropped USB drive
- **Tailgating** also called piggybacking: following an authorised person through a door
- **Shoulder surfing** watching a password being typed
- **Dumpster diving** reading discarded documents and media
- **The defence** awareness training, phishing simulation and easy reporting

These target trust, which no firewall can patch.



HUMAN VECTORS

Network and file-based vectors

- **Unsecured wireless** traffic intercepted where encryption is weak or absent
- **Rogue access point** an unauthorised wireless device users willingly trust
- **On-path attack** the attacker relays traffic between two parties
- **Malicious document** a hidden script or macro runs when the file is opened
- **Infected executable** an altered program installs malware or a backdoor
- **Removable media** malware carried straight past network defences

Encryption and endpoint protection are the countermeasures.



ATTACK SURFACE

Direct access, remote access and open services

- **Direct access** USB ports, console access and wired connections
- **Remote access** VPN, RDP, SSH and remote administration tools
- **Open service ports** unnecessary TCP and UDP services exposed to attackers
- **Default credentials** unchanged factory passwords are public knowledge
- **Watering hole** a site the target trusts is compromised and used to deliver malware
- **The lesson** every one of these is a door, and doors are closed by configuration



BREAK
10 MINUTES

Back soon: the vulnerabilities behind the vectors, then the malware that exploits them.



VULNERABILITIES

Supply chain and software vulnerabilities

- **Supply chain** compromise a supplier to reach the real target
- **Compromised updates** malicious code delivered to every customer at once
- **Vendor credentials** weak supplier security opens the larger target
- **Unpatched system** a known flaw left open between disclosure and fix
- **Misconfiguration** open ports, weak rules and exposed storage
- **Zero-day** an unknown flaw with no patch available yet

NotPetya rode in on the update of a trusted accounting package.



VULNERABILITIES

Application and web vulnerabilities

Vulnerability	What the attacker does
Memory injection	Inserts code into a program and redirects execution
Buffer overflow	Writes past a buffer and overwrites adjacent memory
Race condition	Times events to reach a resource out of turn
SQL injection (sequel)	Changes a database query by injecting input
Cross-site scripting	Runs a script in another user's browser
Cross-site request forgery	Makes a logged-in user submit a request
Session hijacking	Steals a session cookie and takes over the session

The injection succeeds only when code and data are mixed.



VULNERABILITIES

Operating system and hardware vulnerabilities

- **Privilege escalation** ordinary access becomes administrative access
- **Kernel exploit** attack the core of the operating system
- **End-of-life system** no security updates, so known flaws remain
- **Legacy system** old software kept running for compatibility, unpatchable
- **BIOS or UEFI attack** malware that sits below the operating system
- **Side channel** secrets recovered from power use or timing
- **Spectre and Meltdown** speculative execution leaks memory

Low-level flaws survive a reboot, and sometimes a reinstall.



VULNERABILITIES

Mobile, cloud and virtualisation vulnerabilities

- **Jailbreaking** removes the protections too
- **Sideloaded** apps outside the official store
- **Mobile malware** spyware, ransomware, trojans
- **Lost device** portable and easily lost
- **Misconfigured storage** buckets open to the internet
- **Insecure interface** weak cloud authentication
- **Shared responsibility** unclear who secures what
- **VM escape** guest breaks out to the host
- **Hypervisor flaw** every guest is compromised

The weakest platform weakens every platform it can reach.



MALWARE

The malware lifecycle and its types

- **Delivery** an attachment, a malicious website or an infected download
- **Exploitation** abuses a bug, a misconfiguration or a patch never applied
- **Persistence** hidden files and altered settings that survive a reboot
- **Virus** attaches to a file and needs a user to run it
- **Worm** self-propagating, spreading with no user action
- **Trojan** disguised as legitimate software the user installs

Break any one stage and the infection fails.



MALWARE

Evasion techniques

- **Polymorphism** the code rewrites itself with every infection
- **Encryption** the payload is hidden until the moment it runs
- **Rootkit** hides files, processes and network connections
- **Code obfuscation** renamed variables and no comments, to slow an analyst down
- **Fileless malware** lives in memory and abuses a legitimate tool such as PowerShell

Signature detection alone cannot keep up with these.



MALWARE

Ransomware, spyware and rootkits

- **Ransomware** strong encryption, then a demand for payment in cryptocurrency
- **Double extortion** data stolen as well as encrypted, so backups are no defence
- **Spyware** covert collection of habits and credentials
- **Keylogger** records keystrokes, in software or in hardware
- **Rootkit** hidden at a low level with administrative privilege
- **Bootkit** infects the boot process and reinstalls itself at every startup
- **The defence** endpoint protection, patching and tested offline backups



MALWARE

Botnets and command and control

- **Botnet** many compromised machines, called zombies, answering one operator
- **Recruitment** malware spread through phishing and unpatched software
- **Command and control** servers that issue orders and collect results
- **Domain generation algorithms** endless candidate domains defeat blocking
- **Fast flux** addresses rotate rapidly to survive takedown
- **Peer to peer** every bot serves every other, with no central server
- **Uses** spam, denial of service and credential stuffing



CREDENTIALS

Password and credential attacks

Attack	How it works
Brute force	Tries every possible combination, slowly
Dictionary	Tries a list of common and leaked passwords
Password spraying	A few common passwords across many accounts
Credential stuffing	Reused pairs taken from an earlier breach
Offline hash attack	Stolen hashes cracked away from the live system
Rainbow table	Precomputed hashes looked up, not cracked

Lockouts, length, multifactor authentication and hashing with a salt are the answers.



ATTACK TECHNIQUES

Injection and application attacks

- **SQL injection** input changes the query the database runs
- **Command injection** input becomes an operating system command the server runs
- **LDAP injection** input manipulates a directory query
- **Directory traversal** a crafted path reaches files outside the intended folder
- **Interface abuse** no authentication, weak validation or too much data returned
- **The defence** input validation, escaping and parameterised queries

An injection succeeds only when code and data are mixed together.



ATTACK TECHNIQUES

Denial of service and amplification

- **The goal** make a service unavailable to legitimate users
- **Volumetric** flood the bandwidth with traffic
- **Protocol attack** exhaust server resources, such as a TCP synchronise flood
- **Application layer** look like real users: an HTTP flood, or Slowloris
- **Distributed** many machines, often a botnet, so blocking sources is hard
- **Amplification** a small spoofed request, with the large reply sent to the victim
- **The defence** rate limiting, blackholing and an upstream protection service



NETWORK ATTACKS

Layer 2 attacks and their defences

- **VLAN hopping** double tagging or switch spoofing crosses segments
- **Address table flooding** fake hardware addresses fill the switch table
- **ARP poisoning** the attacker's address is linked to another device
- **Spanning Tree attack** the attacker becomes the root bridge
- **Port security** limits the hardware addresses learned per port
- **DHCP snooping** blocks unauthorised configuration servers
- **Dynamic ARP inspection** validates replies against the binding table
- **BPDU guard** disables a port that receives a bridge protocol data unit



NETWORK ATTACKS

DNS attacks and their defences

- **DNS poisoning** false records injected into a resolver cache
- **DNS spoofing** false answers to genuine queries, cache untouched
- **DNS hijacking** the authoritative server or registrar account is taken over
- **The impact** redirection, credential theft and malware delivery
- **DNSSEC** responses are digitally signed and validated
- **Encrypted DNS** queries protected from interception
- **Monitoring** watch for sudden changes in query patterns



NETWORK ATTACKS

Rogue devices and on-path attacks

- **Rogue access point** wireless access that nobody authorised
- **Evil twin** a fraudulent access point that harvests credentials
- **Rogue DHCP server** hands out a false gateway and name server
- **Rogue switch** mirrors traffic to the attacker
- **On-path attack** relays traffic between two trusting parties
- **SSL stripping** downgrades a secure connection to plain text
- **The defence** encryption, certificate validation and wireless scanning



NETWORK ATTACKS

Physical and cryptographic attacks

- **Device theft** possession gives access to data and a foothold
- **Malicious USB device** a dropped drive or charger runs code when connected
- **Badge cloning** duplicate an access card to walk through the door
- **Downgrade attack** force a system to negotiate a weaker protocol version
- **Birthday and collision** two different inputs that produce the same hash
- **Side channel** timing, power or electromagnetic leakage
- **The defence** locked hardware, port control and salted hashing



QUIZ

Activity: name the attack, then the control

- A user is redirected to a fraudulent banking site, with the cache still clean, which attack?
- A switch table fills with invented hardware addresses, which attack, and which two controls?
- A server is overwhelmed by a small spoofed request and a huge reply, which attack?
- A guest network device hands out a false gateway, which device, and which control?
- Debrief: for each answer, name the control that would have stopped it.

Naming the attack and the control together is exactly what a scenario question asks for.



MITIGATION

Segmentation

- **The purpose** divide the network into isolated zones, to contain an attack
- **VLAN** logical separation regardless of physical location
- **Subnet** its own address space and a smaller broadcast domain
- **Microsegmentation** isolate individual workloads and applications
- **Between zones** traffic crosses a router or firewall and is inspected
- **The prize** an attacker who lands in one zone cannot move freely



MITIGATION

Access control

- **Least privilege** the minimum access needed to do the job
- **Need to know** only the information the role requires
- **Separation of duties** no single person controls a whole process
- **In practice** one person authorises a payment, another processes it
- **Review entitlements** access drifts as roles and responsibilities change

Access control limits what a compromise can reach.



MITIGATION

Hardening and patch management

- **Remove what is not needed** services, software, features, ports and protocols
- **Default credentials** change them immediately, because factory passwords are published
- **Firmware updates** apply them, and keep a secure baseline
- **Benchmarks** build from the Centre for Internet Security or NIST guidance
- **Patch discipline** inventory, assess, test, deploy and verify
- **The rule** every service you switch off is a flaw you no longer patch



MITIGATION

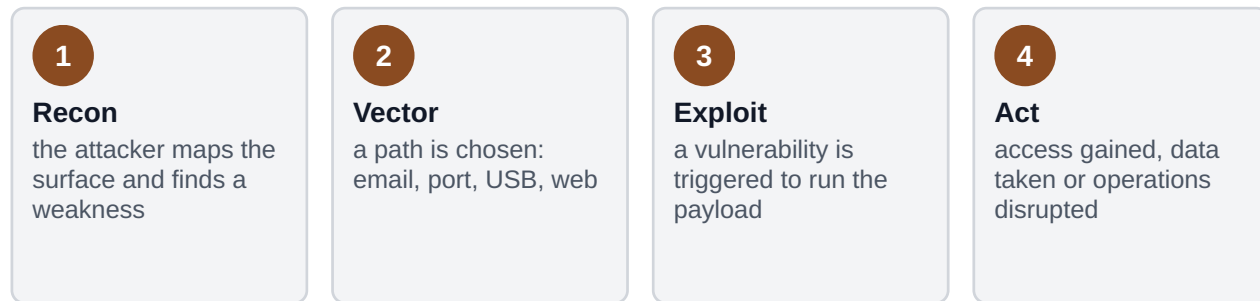
Isolation strategies

- **Sandboxing** run untrusted code in a restricted environment
- **Containerisation** package an application with its dependencies
- **Isolation** containers are separated from each other and from the host
- **Air-gapped system** physically separated from every network, including the internet
- **The cost** updates and data transfers must then be done by hand
- **The purpose** contain the damage so one breach does not cascade



ATTACK CHAIN

Putting it together: the attack chain



The APT lifecycle runs the same chain slowly: recon, intrusion, foothold, escalation, exfiltration, persistence.



EXAM ALIGNMENT

What this maps to in the exam

Objective	What the exam tests
2.1 Threat actors & motivations	Actor types, attributes, motivations, false flags
2.2 Threat vectors & attack surfaces	Vectors, attack surface, vulnerable software, supply chain
2.3 Types of vulnerabilities	Application, operating system, hardware, cloud, virtualisation, zero-day
2.4 Indicators of malicious activity	Malware, botnets, injection, denial of service, Layer 2, DNS, credentials
2.5 Mitigation techniques	Segmentation, least privilege, hardening, patching, isolation

Scenario questions pair an actor with a vector or an attack with a control: answer with both labels.



QUIZ

Check your understanding

- Open Quiz_Session_05.html in your browser.
- 20 questions, immediate feedback, exam-objective tag on every question.
- Read each explanation; the distractors teach as much as the answer.
- Score 70%+ before moving on.

Every question maps to a CompTIA exam objective, from 2.1 Threat Actors to 2.5 Mitigation.



KEY TAKEAWAYS

- **Risk needs a weakness and somebody willing to exploit it** a vulnerability plus a threat.
- **Actors are described by four attributes** resources, sophistication, motivation and intent.
- **Nation-state APTs pursue espionage** organised crime pursues profit.
- **The attack surface includes people** and most vectors start there.
- **Vulnerabilities live everywhere** software, firmware, cloud and virtualisation.



KEY TAKEAWAYS

- **Malware gets in, hides and persists** then spreads through botnets.
- **Passwords fall to spraying, stuffing and offline cracking** length, lockouts and MFA are the answers.
- **Network attacks target trust and availability** Layer 2, DNS, denial of service and on-path.
- **Segment, apply least privilege, harden and patch** then isolate what is left.
- **Defence in depth is the only answer that survives one failure** assume a breach, then contain it.



REVISION CHECKLIST

Before next session

- **Retake the quiz** until you score 70%+ without guessing
- **Profile an actor** research one real threat group and classify it by the four attributes
- **Map your surface** five physical, five technical and five human vectors
- **Pair attacks with controls** ten attacks from this session, and the control that answers each
- **Read ahead** Session 6, cryptography and public key infrastructure



NEXT SESSION

Session 6 · Cryptography & Public Key Infrastructure

- Symmetric, asymmetric and hashing: what each is for
- Digital signatures and non-repudiation in practice
- PKI, certificates, revocation and key management

